WAPH-Web Application Programming and Hacking

Instructor: Dr. Phu Phung

Team Project

Project Topic/Title

Team members

1. Omkar Sontake 1, sontakor@mail.uc.edu
2. Akshat Chaturvedi 2, chaturat@mail.uc.edu

Project Management Information

Source code repository (private access): https://github.com/***

Project homepage (public): https://***.github.io

Revision History

Date	Version	Description
02/07/YYYY	0.0	Init draft
02/12/2024	0.1	Sprint 1.0
02/12/2024	0.2	Sprint 1.0

Overview

Describe the overview of the project with a high-level architecture figure. *Note: You need to update this section according to each sprint*

Sprint 0: For this lab we created a SSL key and setup HTTPS and team local domain name. Additionaly we updated the index.html to include the teams personal portfolio website links and quick introduction to us. # System Analysis *(Start from Sprint 0, keep updating)*

Sprint 0 Through the index.html we were able provide a quick introduction to ourselver. Additionally by creating the SSL key/Certificate we will be able to make thhe website secured.

Sprint 1 Added features to website/application that include register user, edit profile, login, logout, check profile.

High-level Requirements

List high-level requirements of the project that your team will develop into use cases in later steps

System Design

Sprint 1 For Sprint 1 of the project, the we focused on establishing the foundational function of the web application. This includes designing and implementing the database, which may be incomplete and subject to updates. Key functionalities we developed are user registration and login, allowing users to change their passwords, edit their profiles (including name, additional email, and phone), and view posts from the database.

(Start from Sprint 1, keep updating)

Use-Case Realization

Database

Sprint 1 We created a user waph_team13 and also created a database names waph_13. In the database we created tables users,chat_messages,comments,posts,profiles,superusers,users. ## User Interface We utilized html and css to build a simple ui. This ui makes everything very accessible to the user. # Implementation

(Start from Sprint 1, keep updating. However, it is important to prepare the technology from Sprint 0)

For each new sprint cycle, update the implementation of your system (break it down into subsections). Please include some code snippets to illustrate the implementation.

Specify your team's development approach, including programming languages, databases, development, testing, and deployment environments.

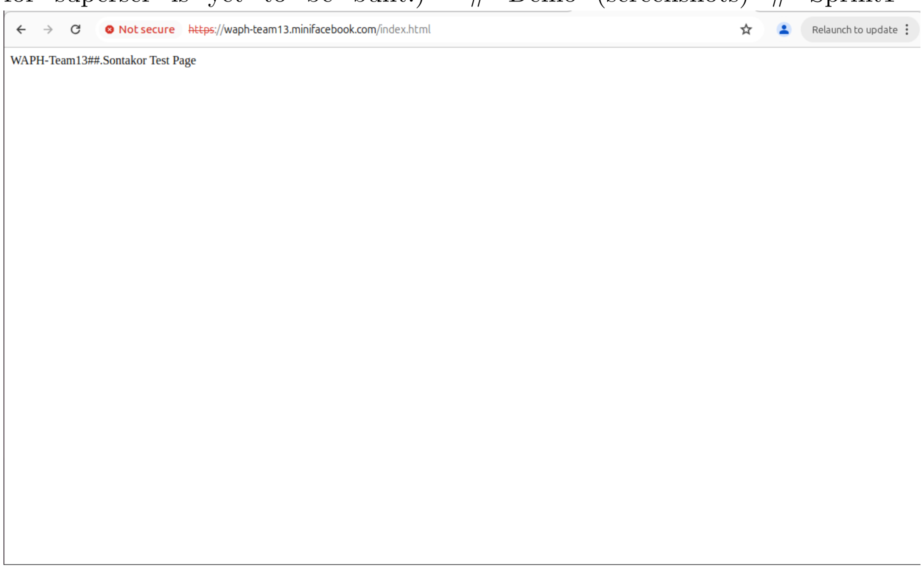
In **Sprint 1**, we used PHP, HTML, and CSS, and sql to exclusively utiliz prepared statements to prevent SQL injection and enforced HTTPS along with hashing passwords before storing them in the database for enhanced security. We faced difficults with databases so all the work for these projects were done on (Omkar's Laptop.) As a result we would meet up so that we could each do our work indivisually on Omkars Laptop. Adter building each functionality we tested we page to unsure that functionaly of the page was well developed.

Security analysis

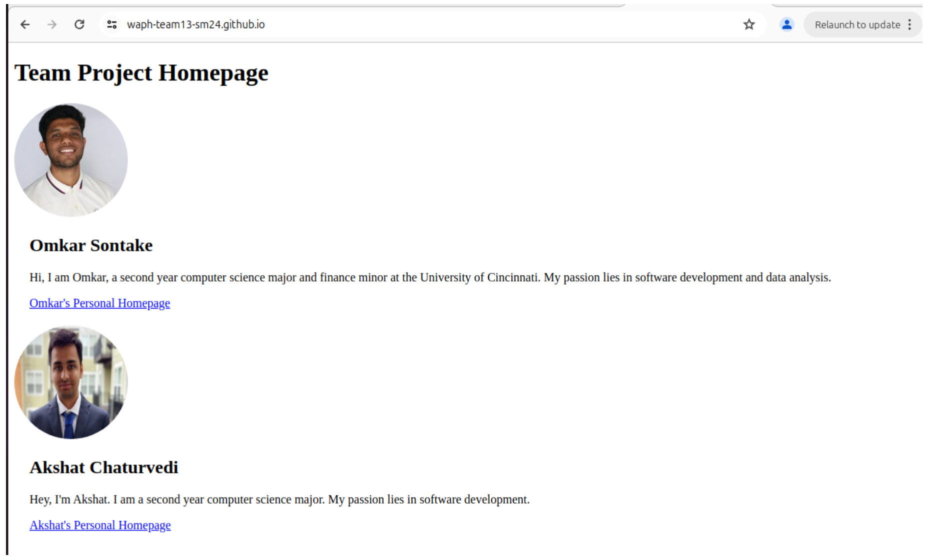
Include a brief explanation of your implementation and the security aspects based on the following questions:

- How did you apply the security programming principles in your project?
- What database security principles have you used in your project?
- Is your code robust and defensive? How?
- How did you defend your code against known attacks such as XSS, SQL Injection, CSRF, Session Hijacking
- How do you separate the roles of super users and regular users?

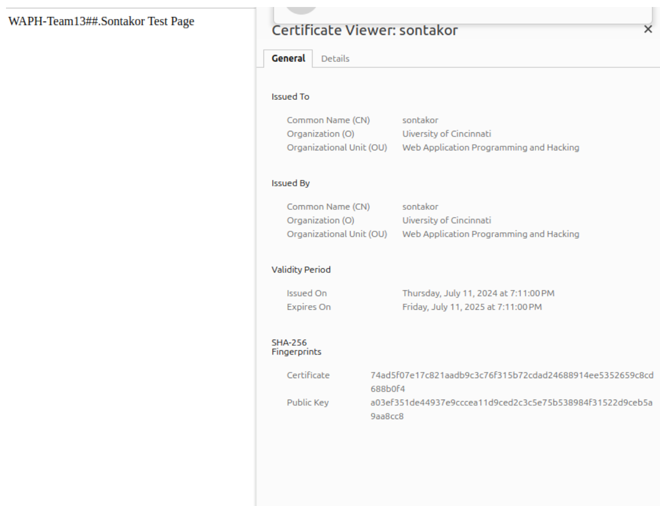
In **Sprint 1**, we applied several security programming principles such as input validation and sanitization to limit permissions and ensure secure handling of user input. Additionally, we exclusively used prepared statements in our PHP code to prevent SQL injection attacks and enforced HTTPS for secure communication. Lastly we hashed passwords before storing them in the database to protect user credentials. We also implemented role separation by creating a superusers table, allowing super users to disable accounts while regular users have limited access.(Functionality for superser is yet to be built.) # Demo (screenshots) # Sprint1 -

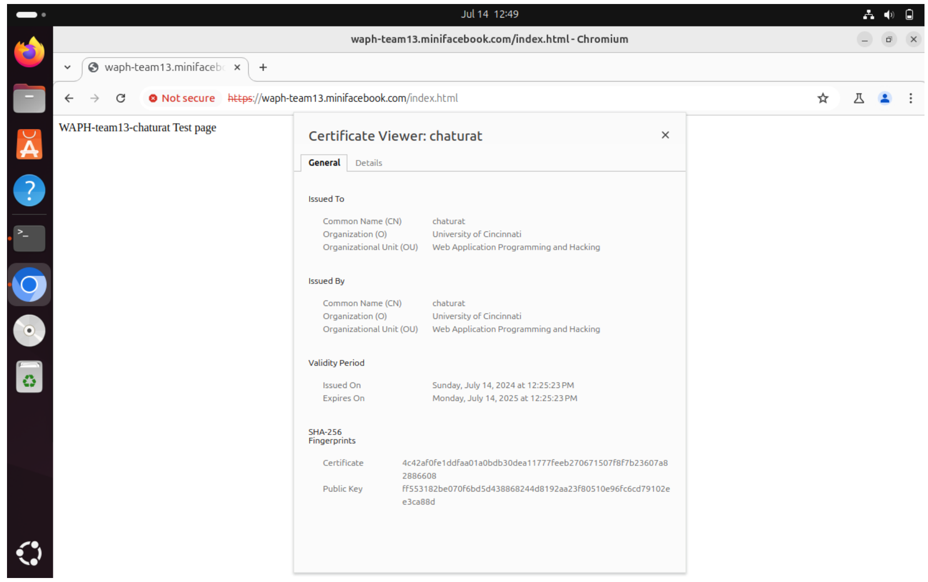


Sprint 0: Screenshot 1 -



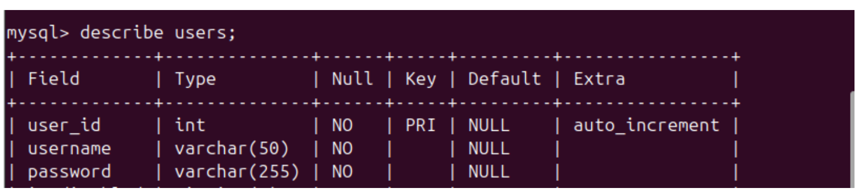
Sprint 0: Screenshot 2 -





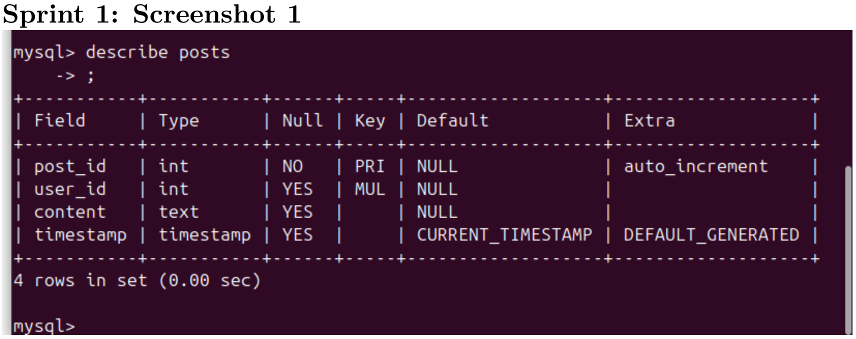
Sprint 0: Screenshot 3 -
Sprint 0: Screenshot 4

Sprint 2

- 

```
mysql> describe users;
+-------------+--------------+------+-----+---------+----------------+
| Field       | Type         | Null | Key | Default | Extra          |
+-------------+--------------+------+-----+---------+----------------+
| user_id     | int          | NO   | PRI | NULL    | auto_increment |
| username    | varchar(50)  | NO   |     | NULL    |                |
| password    | varchar(255) | NO   |     | NULL    |                |
```

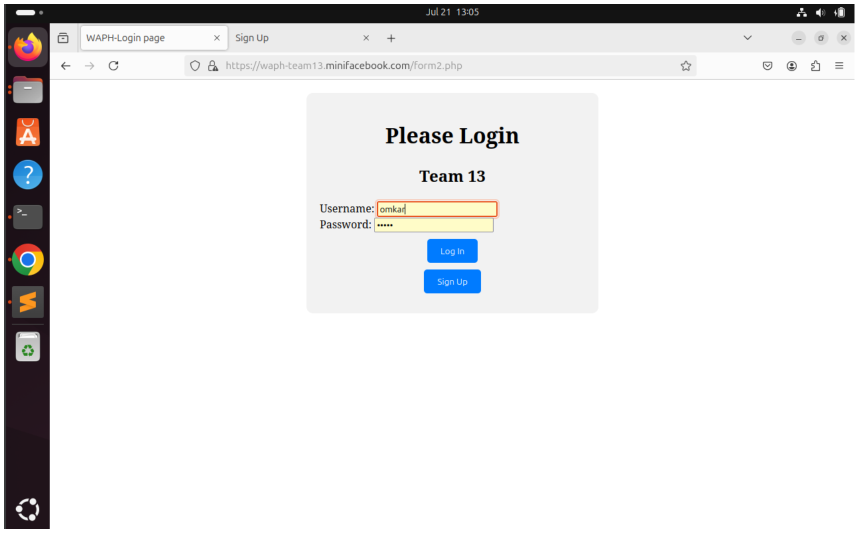
  Sprint 1: Screenshot 1

- 

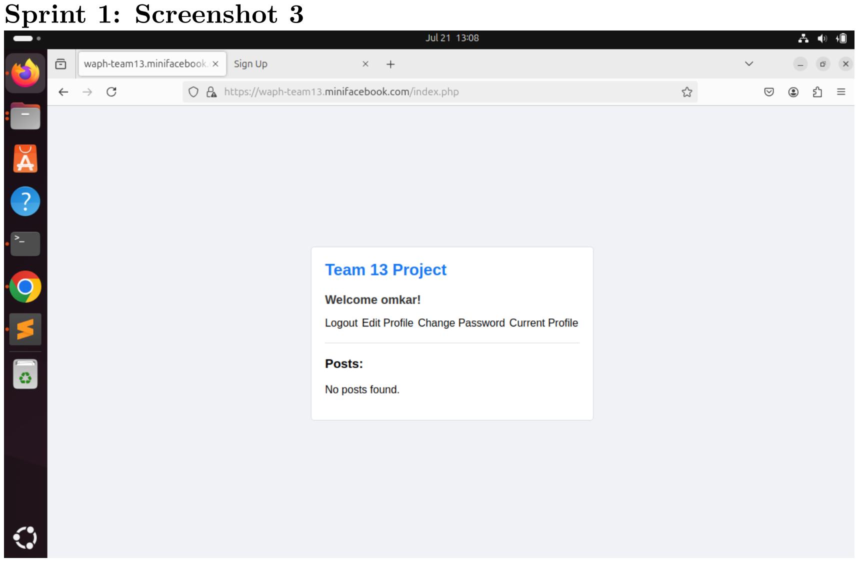
```
mysql> describe posts
    -> ;
+-----------+-----------+------+-----+-------------------+-------------------+
| Field     | Type      | Null | Key | Default           | Extra             |
+-----------+-----------+------+-----+-------------------+-------------------+
| post_id   | int       | NO   | PRI | NULL              | auto_increment    |
| user_id   | int       | YES  | MUL | NULL              |                   |
| content   | text      | YES  |     | NULL              |                   |
| timestamp | timestamp | YES  |     | CURRENT_TIMESTAMP | DEFAULT_GENERATED |
+-----------+-----------+------+-----+-------------------+-------------------+
4 rows in set (0.00 sec)

mysql>
```

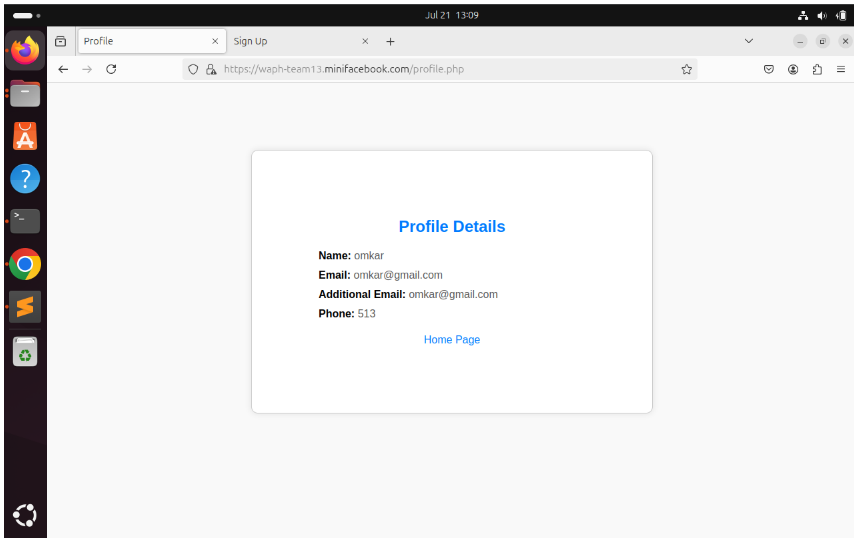
  Sprint 1: Screenshot 2

- 

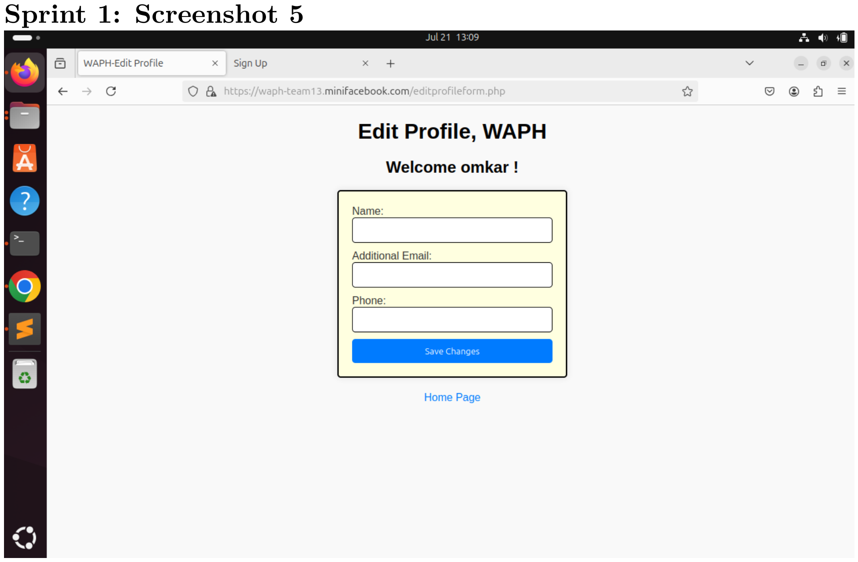
Sprint 1: Screenshot 3

- 

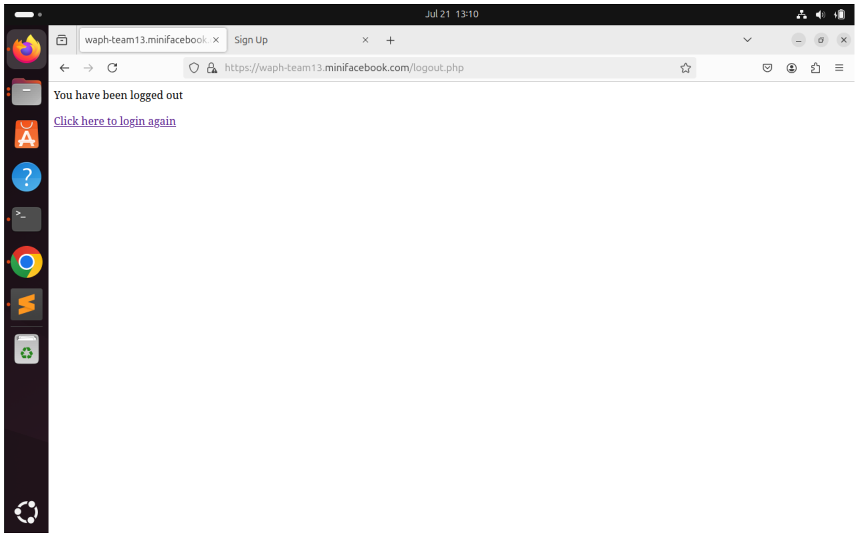
Sprint 1: Screenshot 4

- 

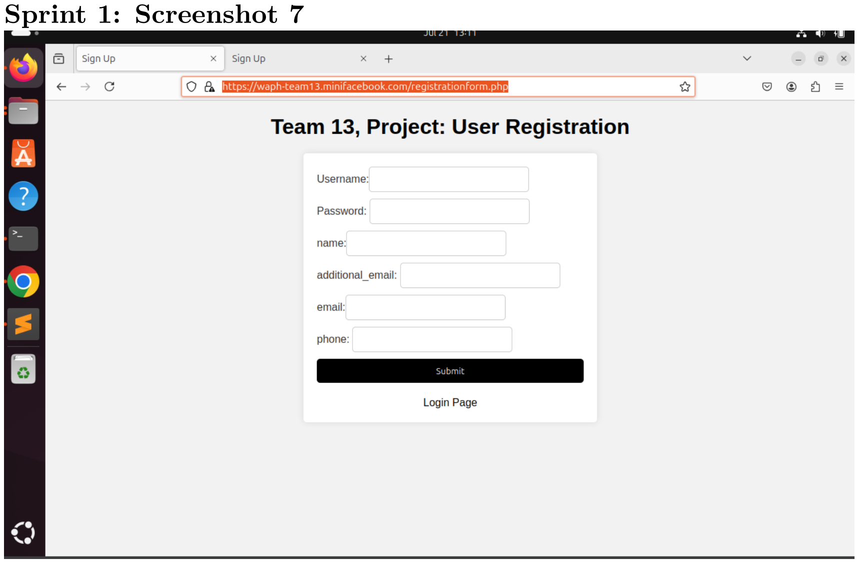
  Sprint 1: Screenshot 5

- 

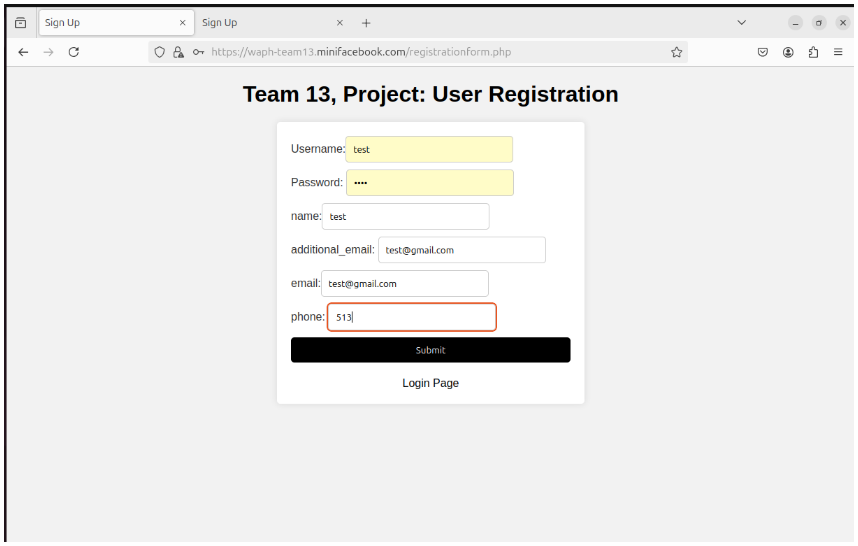
  Sprint 1: Screenshot 6

- 

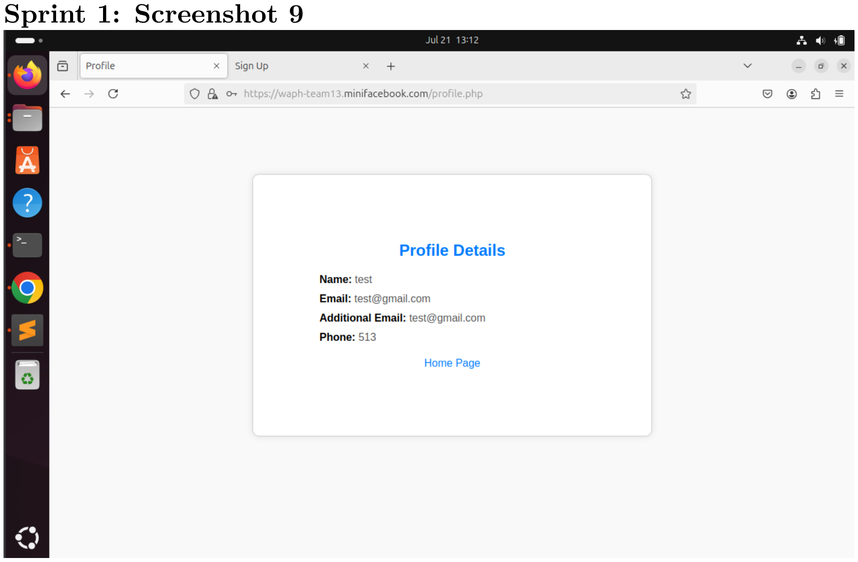
Sprint 1: Screenshot 7

- 

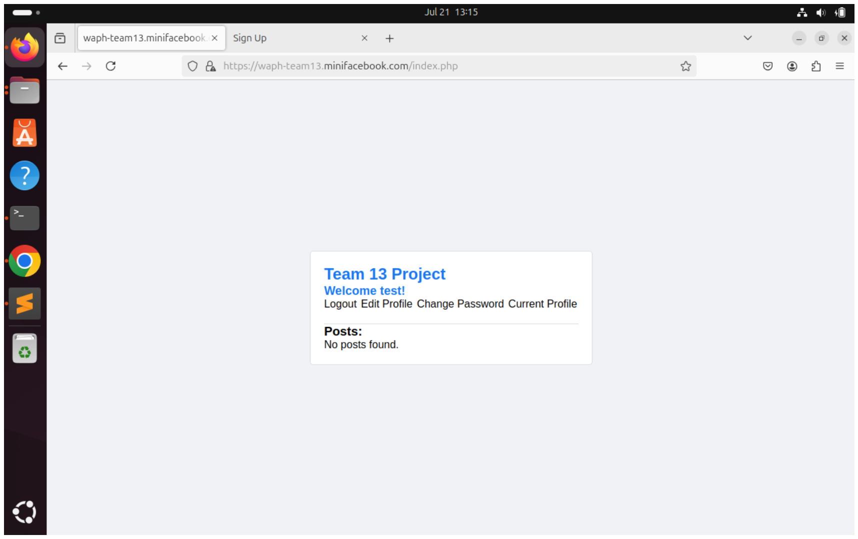
**Sprint 1: Screenshot 78*

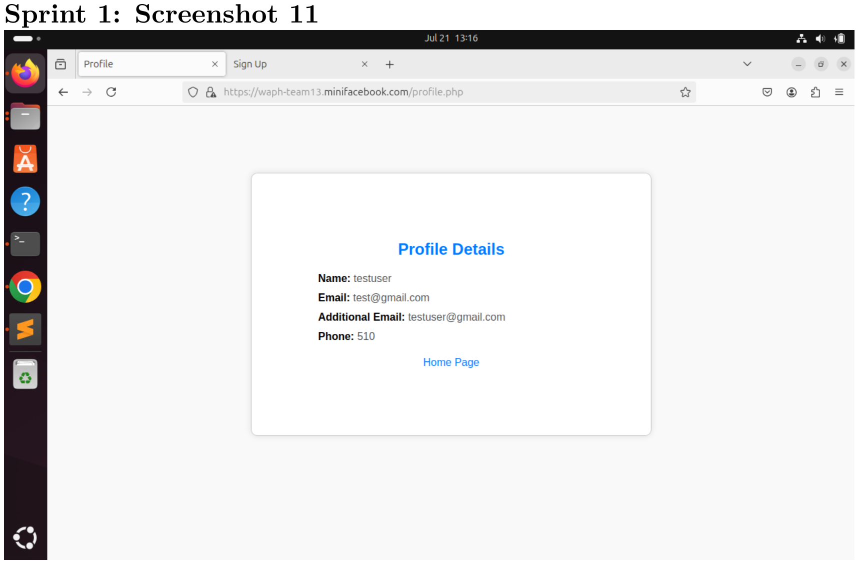
- 

Sprint 1: Screenshot 9

- 

Sprint 1: Screenshot 10

- 

  Sprint 1: Screenshot 11
- 

  Sprint 1: Screenshot 12

You need to capture screenshots to demonstrate how your web application works. The screenshots must be accompanied by a short description of its functionalities following the implementation as below:

- Everyone can register a new account and then login
- Superuser can disable an account
- The disabled account cannot log in
- Superuser can enable the disabled account
- The enabled user can log in
- A regular logged-in user can delete her own existing posts but cannot delete

the posts of others

- CSRF attack to delete a post should be detected and prevented
- A regular logged-in user cannot access the link for superusers
- A logged-in user can have a real-time chat with other logged-in users

Software Process Management

(Start from Sprint 0, keep updating) **Sprint 0** Our team communicated through teams. We set-up timings everyday so that we can meet and discuss our progress and places where we were stuck. By helping each other through this methods we were able to complete the assignment succesfully.

Introduce how your team uses a software management process, e.g., Scrum, and how your teamwork collaborates.

Scrum process

Sprint 0

Duration: DD/MM/YYYY-DD/MM/YYYY

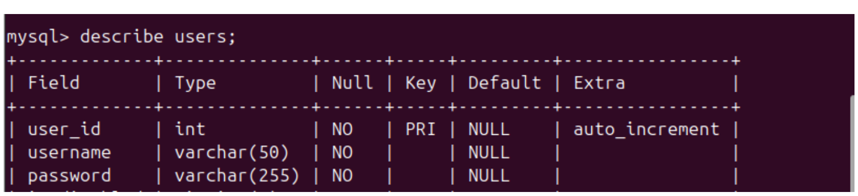
Completed Tasks: **Sprint 0** 1. Certificate 2. team database 3. Index.html

Contributions:

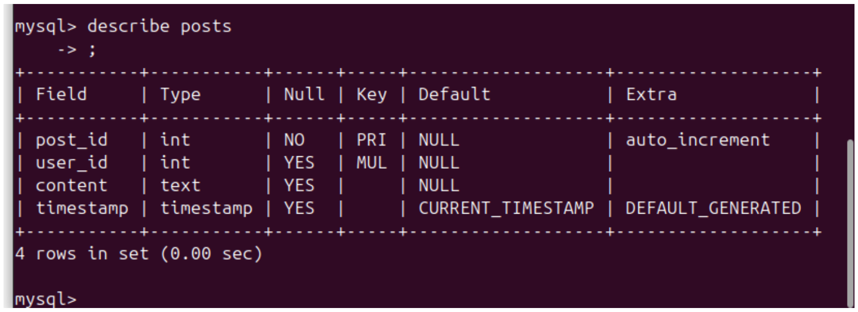
1. Omkar, 2 commits, 1 hours, contributed in readme.md
2. Akshat, 2 commits, 1 hours, contributed in index.html
3. Member 3, x commits, y hours, contributed in xxx
4. Member 4, x commits, y hours, contributed in xxx

Sprint 1

We have created our team's sql server named 'waph_13' in which we have stored the required databases and the tables.

- 

  Sprint 1: Screenshot 1

- 

```
mysql> describe posts
    -> ;
+-----------+-----------+------+-----+-------------------+-------------------+
| Field     | Type      | Null | Key | Default           | Extra             |
+-----------+-----------+------+-----+-------------------+-------------------+
| post_id   | int       | NO   | PRI | NULL              | auto_increment    |
| user_id   | int       | YES  | MUL | NULL              |                   |
| content   | text      | YES  |     | NULL              |                   |
| timestamp | timestamp | YES  |     | CURRENT_TIMESTAMP | DEFAULT_GENERATED |
+-----------+-----------+------+-----+-------------------+-------------------+
4 rows in set (0.00 sec)

mysql>
```

  Sprint 1: Screenshot 2

Duration: 07/15/2024-07/21/2024

Completed Tasks:

1. Database design and implementation
2. User registration and login
3. Change password
4. Edit their profile, including name, additional email, phone

Contributions:

1. Omkar , 1 commits, 5 hours, login, signup, editprofile, index(home screen) functionalitites.
2. Akshat, 1 commits, 4.5 hours, developed databases schema,logout, current profile functionalities.

Sprint Retrospection: _(Introduction to Sprint Retrospection:

Working through the sprints is a continuous improvement process. Discussing the completed sprint can improve the next sprint walk through a much more efficient one. Sprint retrospection is done once a sprint is finished and the team is ready to start another sprint planning meeting. This discussion can take up to 1 hour depending on the ideal team size of 4 members. Discussing good things that happened during the sprint can improve the team's morale, good team collaboration, appreciating someone who did a fantastic job solving a blocker issue, work well-organized, and helping someone in need. This will improve the team's confidence and keep them motivated. As a team, we can discuss what has gone wrong during the sprint and come up with improvement points for the next sprints. Few points can be like, need to manage time well, need to prioritize the tasks properly and finish a task in time, incorrect design lead to multiple reviews and that wasted time during the sprint, team meetings were too long which consumed most of the effective work hours. We can mention every problem is in the sprint which is hindering the progress. Finally, this meeting should improve your next sprint drastically and understand the team dynamics well. Mention the bullet points and discuss how to solve it.)

Good	Could have been better	How to improve?

Good: Developing front end using html css was easy and well done. **Could have been better:** We could have spent some more time ensure that we have all the necassitites for the future sprints.When we because developing this part of the project we faced issues with connecting the sql database and our php code. We ended up having to restart everything from the code to installation of sql. **How to improve?** In order to improve we must plan ahead so that incase such instance like this happen we arent too late and are able to complete our requried tasks in a timely manner.

Sprint 1

Duration: 07/15/2024-07/21/2024

Completed Tasks:

1. Database design and implementation
2. User registration and login
3. Change password
4. Edit their profile, including name, additional email, phone

Contributions:

1. Member 1, x commits, y hours, contributed in xxx
2. Member 2, x commits, y hours, contributed in xxx
3. Member 3, x commits, y hours, contributed in xxx
4. Member 4, x commits, y hours, contributed in xxx

Sprint Retrospection:

Good	Could have been better	How to improve?

Appendix

Include the content (in text, not as images) of the SQL files and all source code of your PHP files (with the file name).